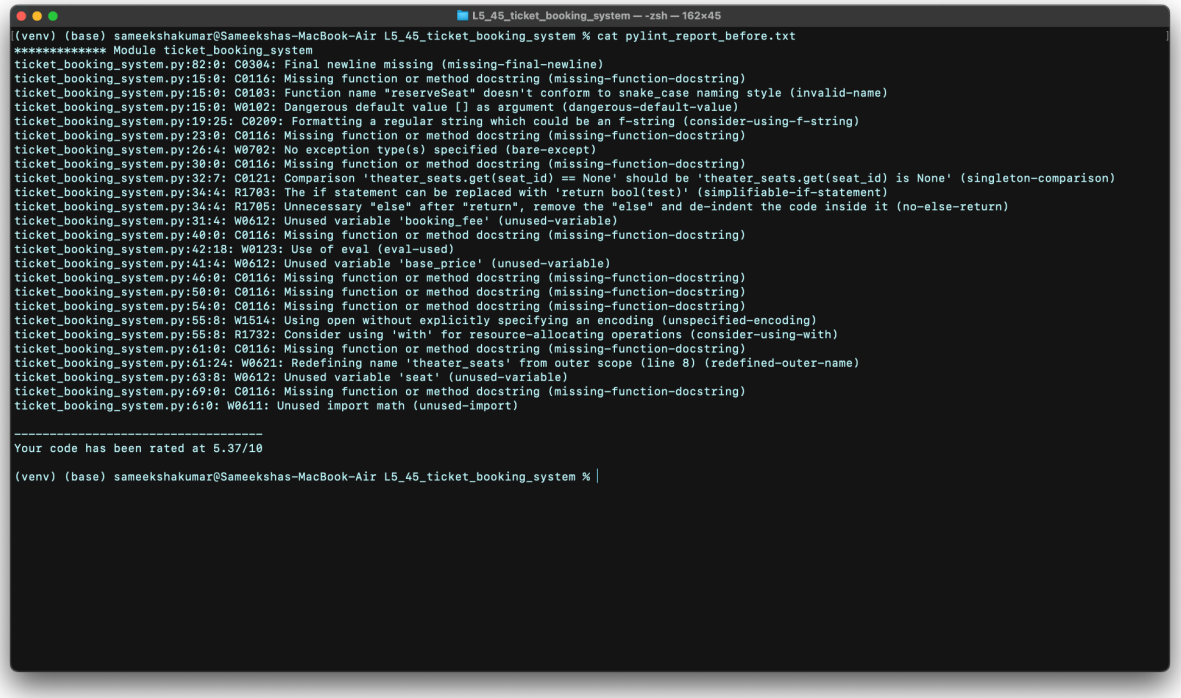
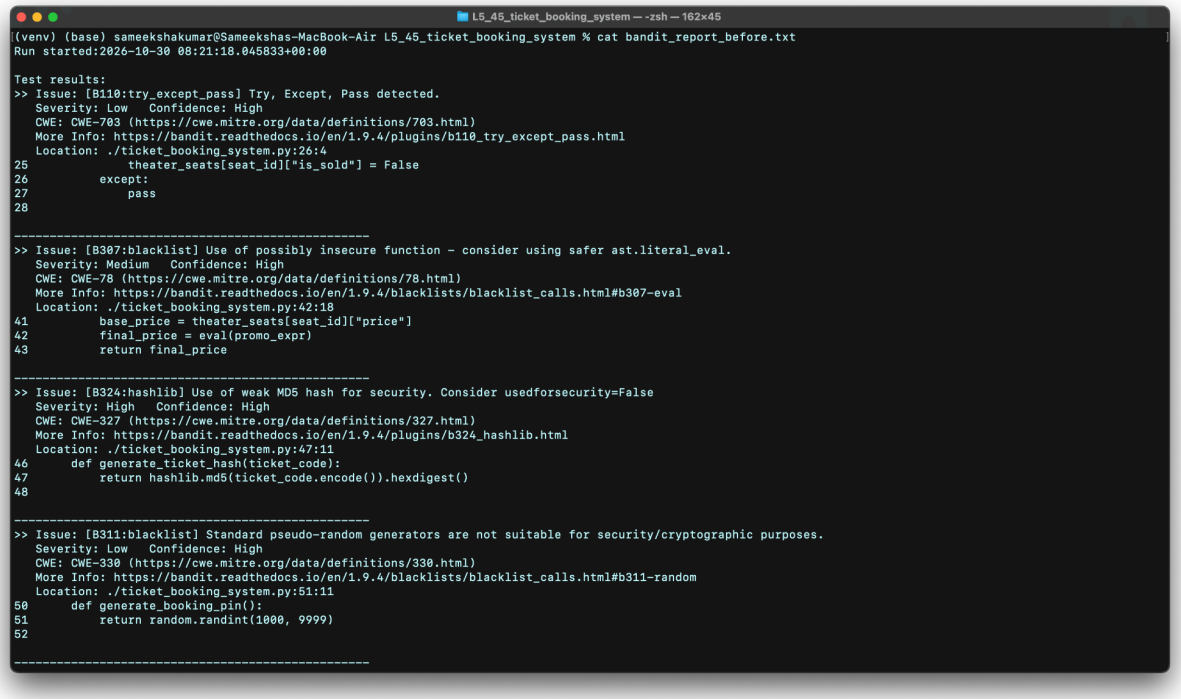
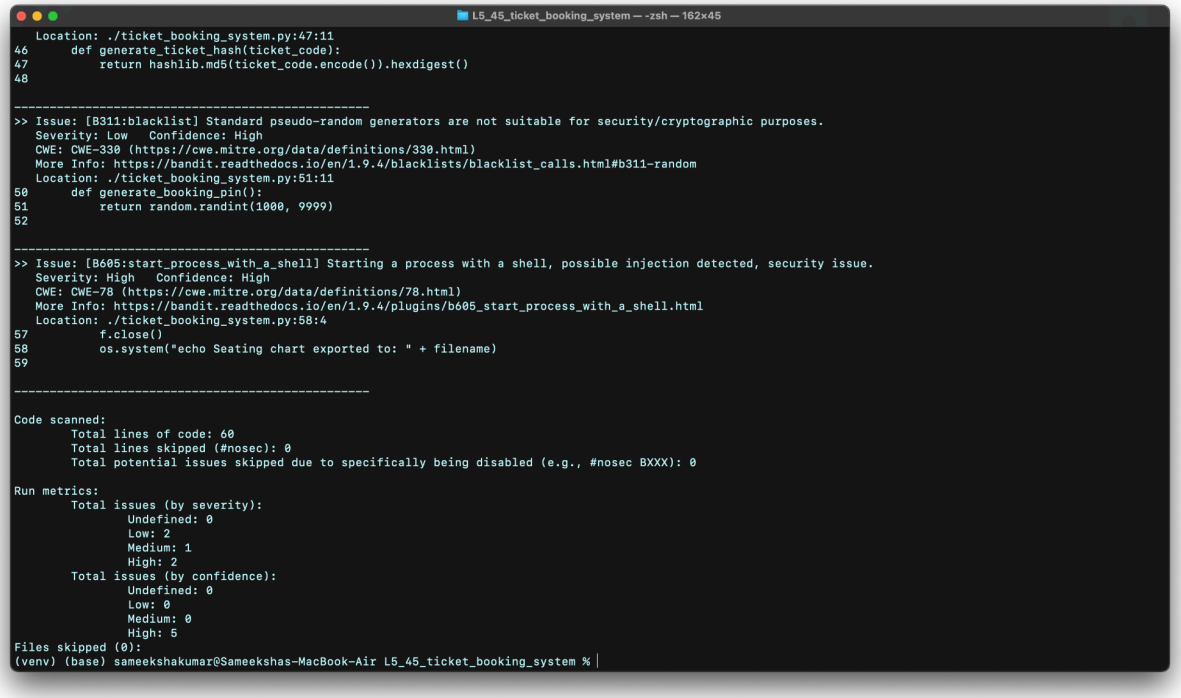
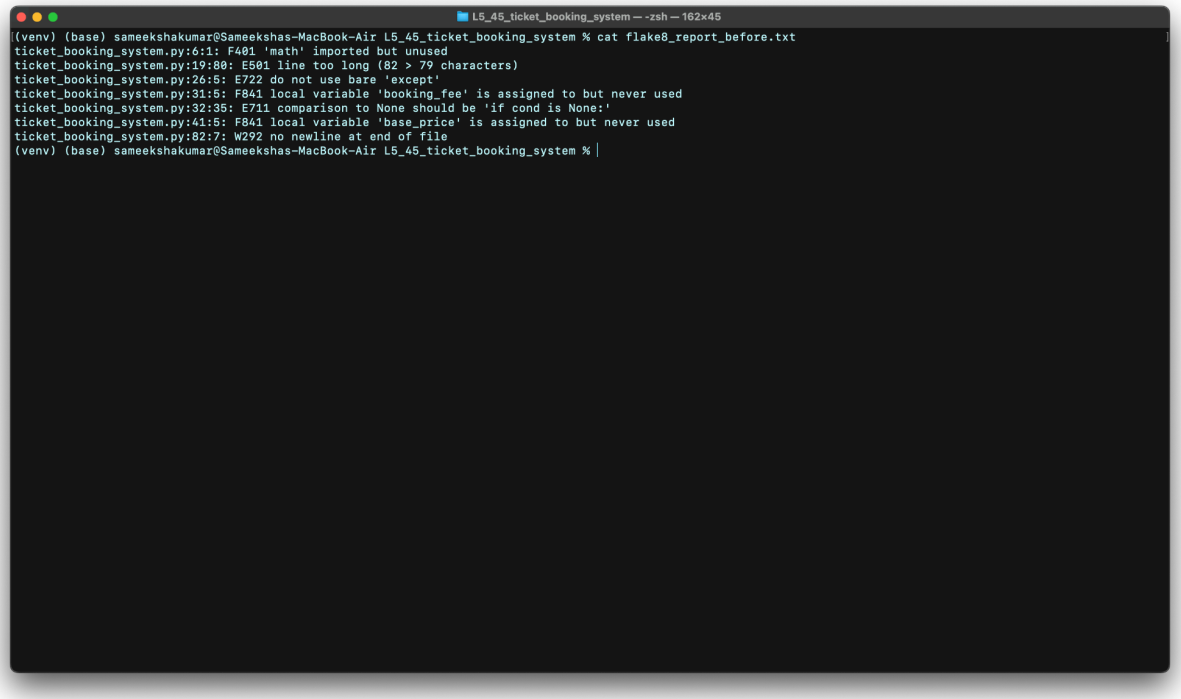
Name: Sameeksha Prasanna Kumar
SRN: PES1UG24CS410
Section: G
Lab 5: Static Code Analysis
Repo name: L5_45_ticket_booking_system

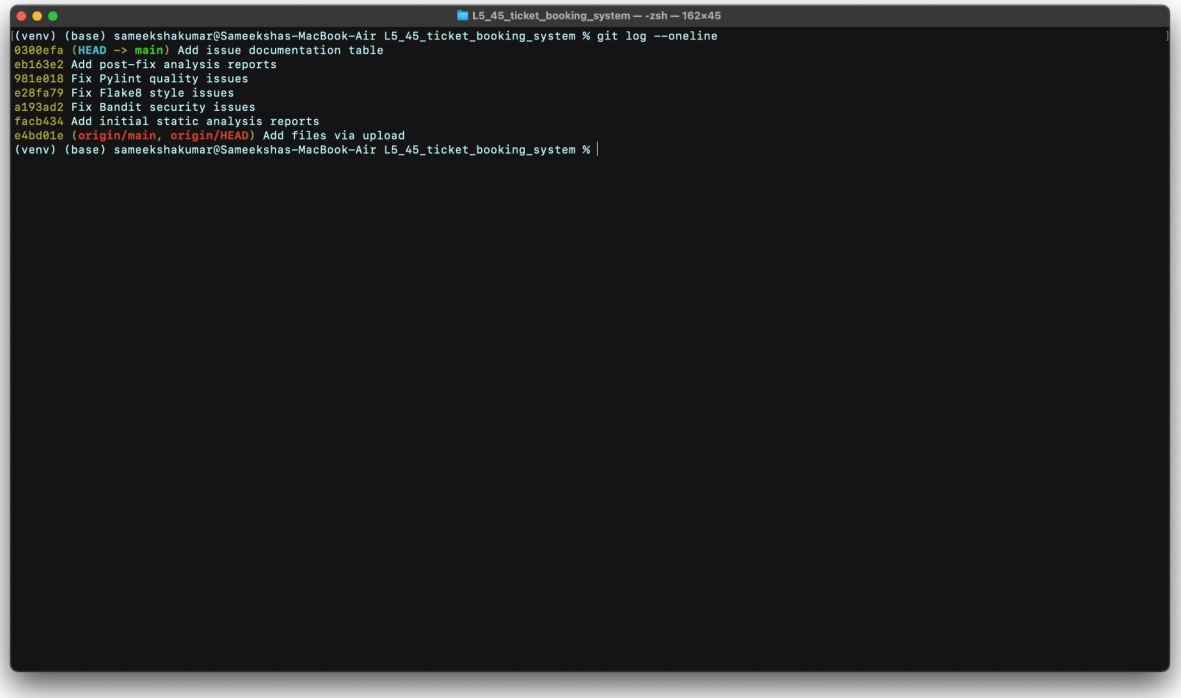
Screenshots:

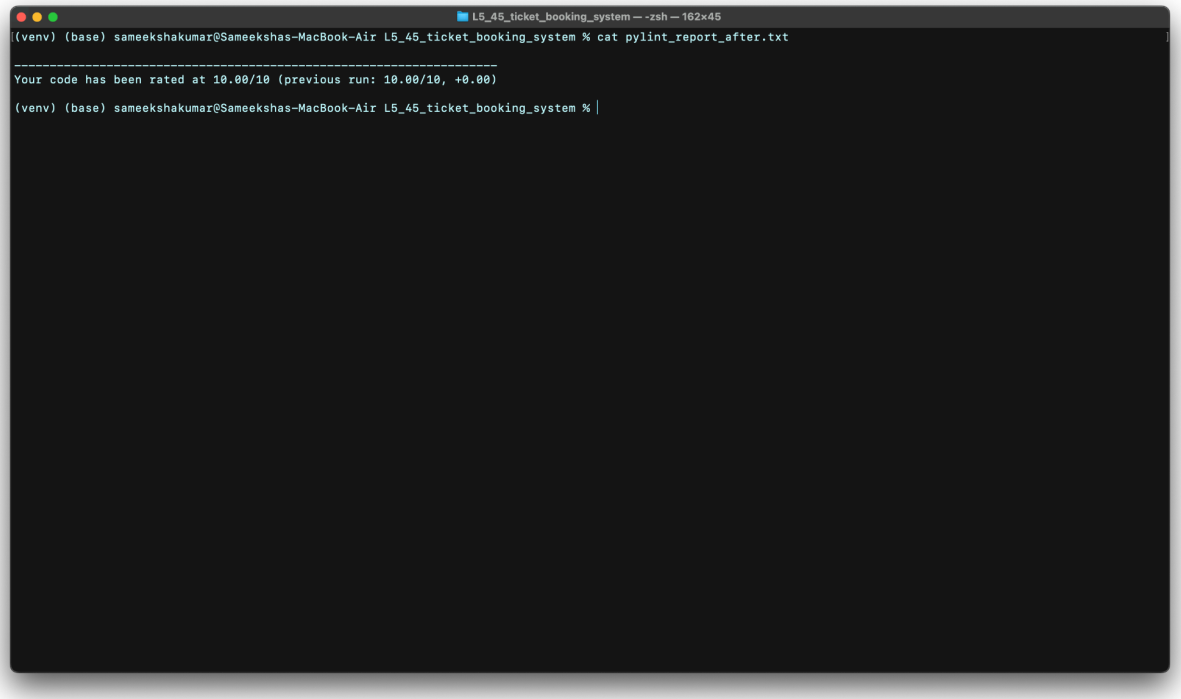


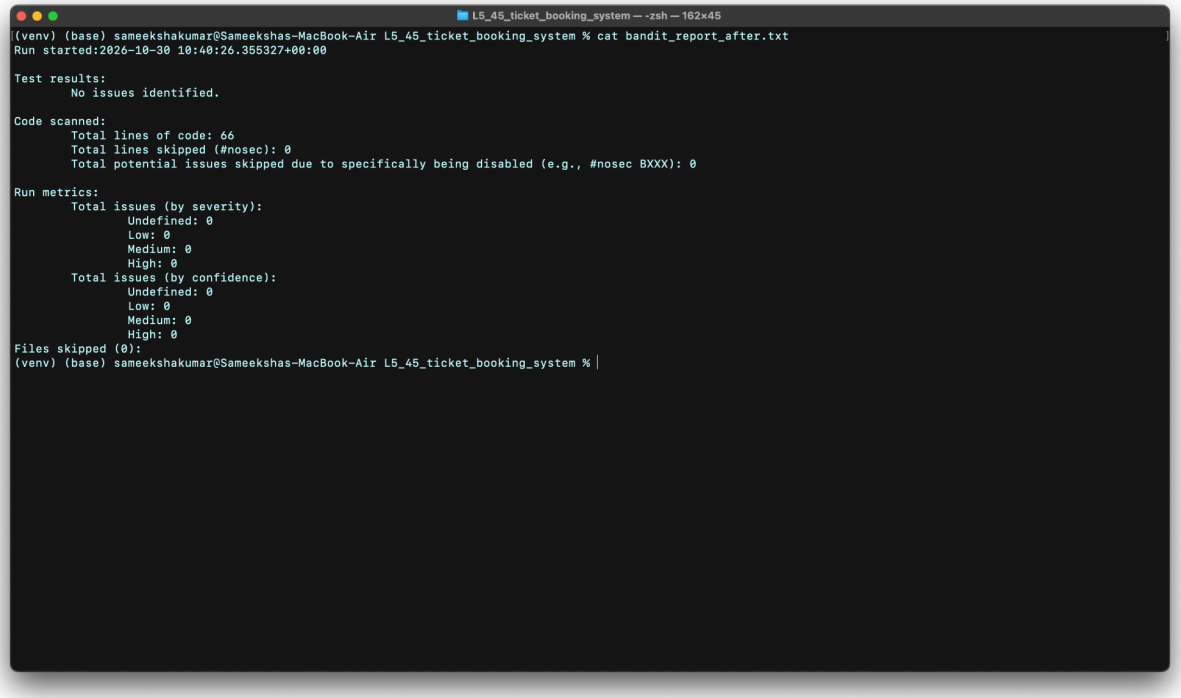

L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % cat bandit_report_before.txt
Run started:2026-10-30 08:21:18.045833+00:00
Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
Severity: Low Confidence: High
CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
Location: ./ticket_booking_system.py:26:4
25 theater_seats[seat_id]["is_sold"] = False
26 except:
27 pass
28
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
Severity: Medium Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
Location: ./ticket_booking_system.py:42:18
41 base_price = theater_seats[seat_id]["price"]
42 final_price = eval(promo_expr)
43 return final_price
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
Severity: High Confidence: High
CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
Location: ./ticket_booking_system.py:47:11
46 def generate_ticket_hash(ticket_code):
47 return hashlib.md5(ticket_code.encode()).hexdigest()
48
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
Severity: Low Confidence: High
CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
Location: ./ticket_booking_system.py:51:11
50 def generate_booking_pin():
51 return random.randint(1000, 9999)
52

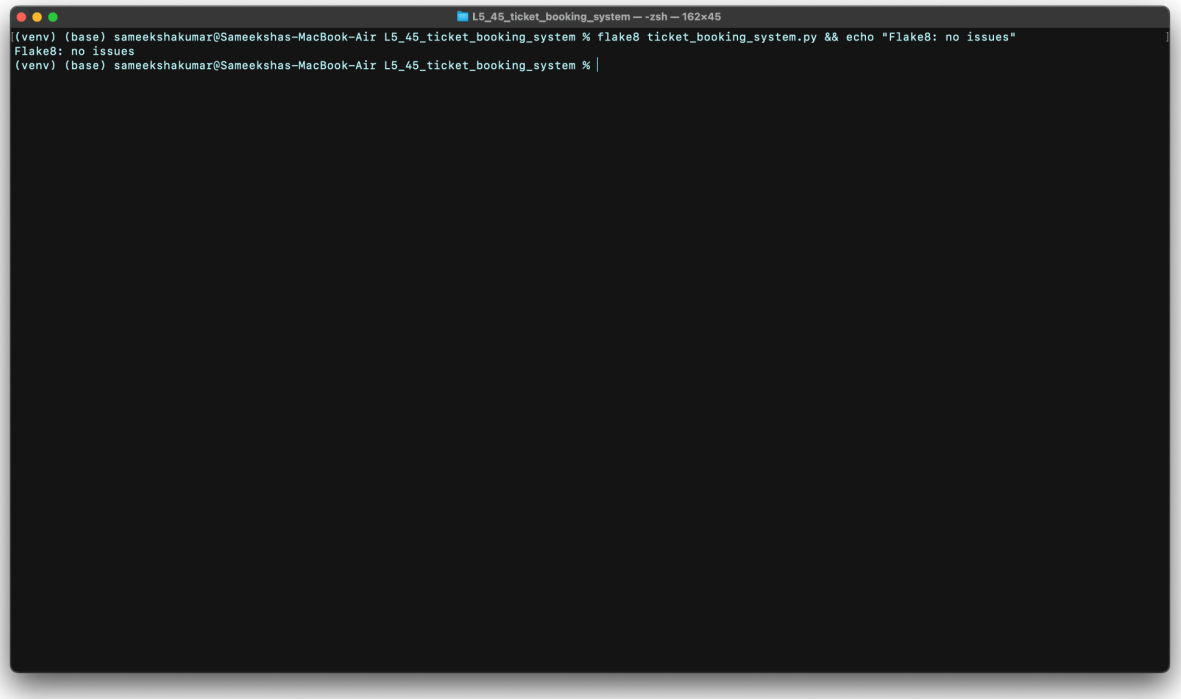

L5_45_ticket_booking_system — -zsh — 162×45
Location: ./ticket_booking_system.py:47:11
46 def generate_ticket_hash(ticket_code):
47 return hashlib.md5(ticket_code.encode()).hexdigest()
48
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
Severity: Low Confidence: High
CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
Location: ./ticket_booking_system.py:51:11
50 def generate_booking_pin():
51 return random.randint(1000, 9999)
52
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
Severity: High Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
Location: ./ticket_booking_system.py:58:4
57 f.close()
58 os.system("echo Seating chart exported to: " + filename)
59
Code scanned:
Total lines of code: 60
Total lines skipped (#nosec): 0
Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
Run metrics:
Total issues (by severity):
Undefined: 0
Low: 2
Medium: 1
High: 2
Total issues (by confidence):
Undefined: 0
Low: 0
Medium: 0
High: 5
Files skipped (0):
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %

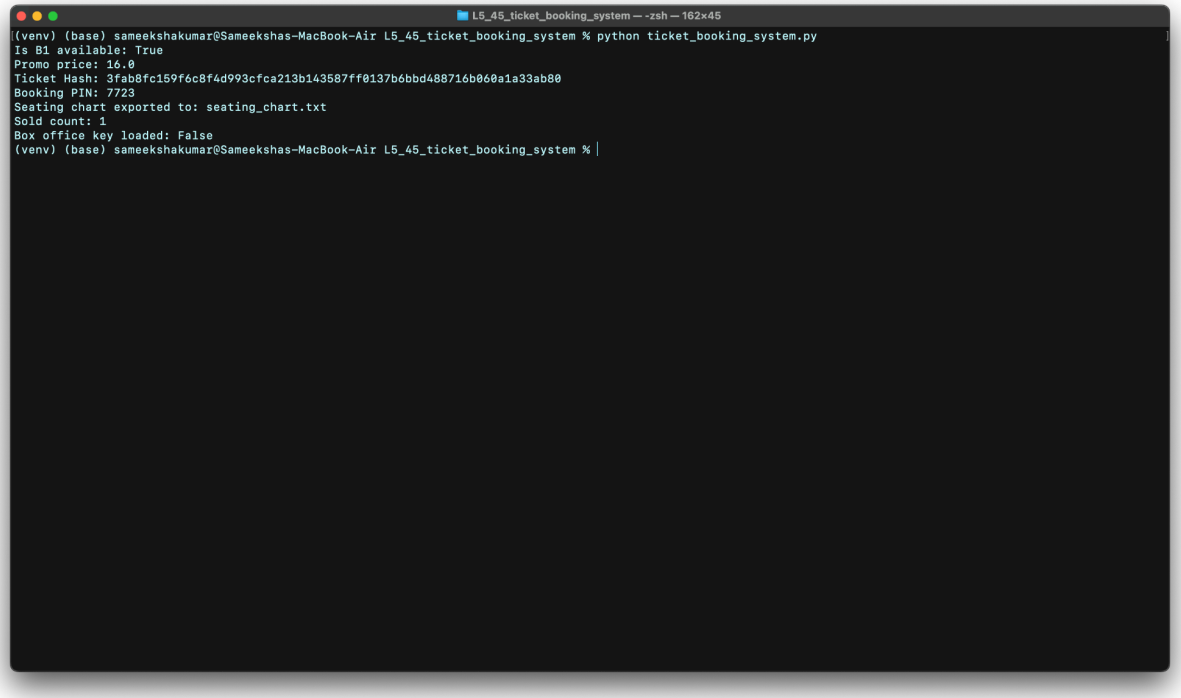

L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % cat flake8_report_before.txt
ticket_booking_system.py:6:1: F401 'math' imported but unused
ticket_booking_system.py:19:80: E501 line too long (82 > 79 characters)
ticket_booking_system.py:26:5: E722 do not use bare 'except'
ticket_booking_system.py:31:5: F841 local variable 'booking_fee' is assigned to but never used
ticket_booking_system.py:32:35: E711 comparison to None should be 'if cond is None:'
ticket_booking_system.py:41:5: F841 local variable 'base_price' is assigned to but never used
ticket_booking_system.py:82:7: W292 no newline at end of file
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %


L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % git log --oneline
0300efa (HEAD -> main) Add issue documentation table
eb163e2 Add post-fix analysis reports
981e018 Fix Pylint quality issues
e28fa79 Fix Flake8 style issues
a193ad2 Fix Bandit security issues
facb434 Add initial static analysis reports
e4bd01e (origin/main, origin/HEAD) Add files via upload
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %

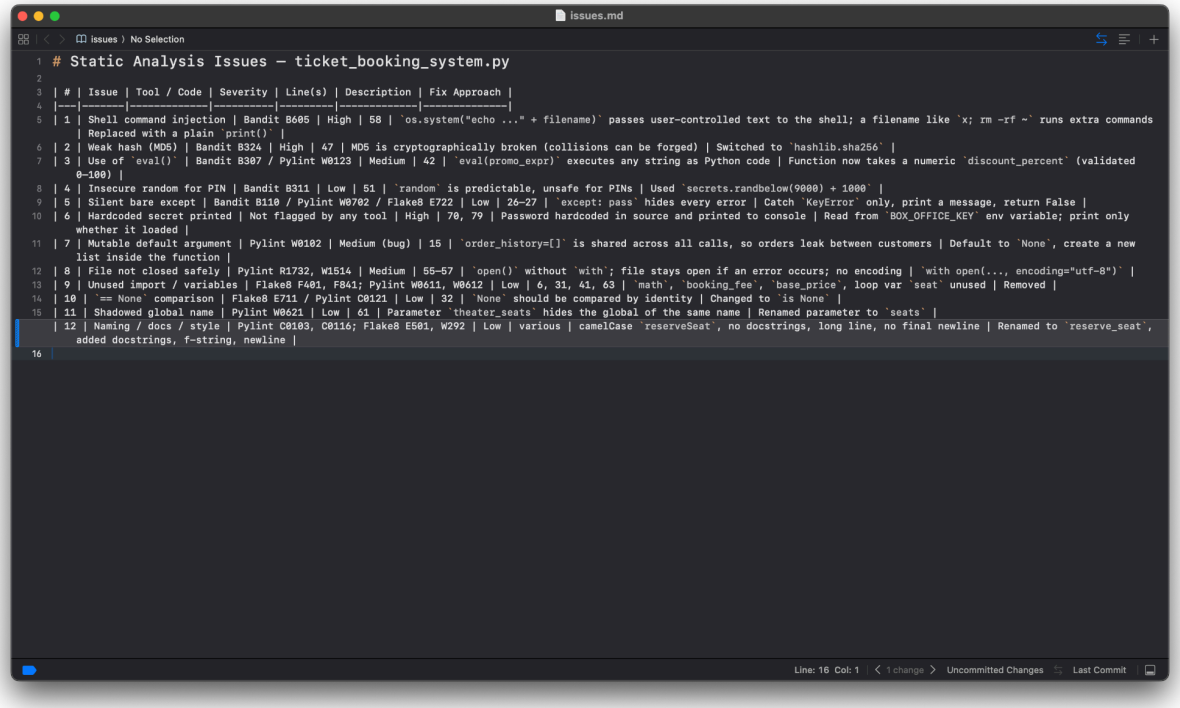

L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % cat pylint_report_after.txt
----
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %


L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % cat bandit_report_after.txt
Run started:2026-10-30 10:40:26.355327+00:00
Test results:
No issues identified.
Code scanned:
Total lines of code: 66
Total lines skipped (#nosec): 0
Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
Run metrics:
Total issues (by severity):
Undefined: 0
Low: 0
Medium: 0
High: 0
Total issues (by confidence):
Undefined: 0
Low: 0
Medium: 0
High: 0
Files skipped (0):
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %


L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % flake8 ticket_booking_system.py && echo "Flake8: no issues"
Flake8: no issues
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %


L5_45_ticket_booking_system — -zsh — 162×45
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system % python ticket_booking_system.py
Is B1 available: True
Promo price: 16.0
Ticket Hash: 3fab8fc159f6c8f4d993cfca213b143587ff0137b6bbd488716b060a1a33ab80
Booking PIN: 7723
Seating chart exported to: seating_chart.txt
Sold count: 1
Box office key loaded: False
(venv) (base) sameekshakumar@Sameekshas-MacBook-Air L5_45_ticket_booking_system %

Issues.md:



reflections.md:

reflection.md

reflection ⟩ Reflection — Lab 5: Static Code Analysis

Reflection — Lab 5: Static Code Analysis

1. Which issues were the easiest to fix, and which were the hardest? Why?

The easiest were the Flake8 style issues: the unused `math` import, the unused `booking_fee` variable, `== None` → `is None`, and the missing final newline. Each was a one-line change with an obvious fix.

The hardest was replacing `eval()`. Removing it meant changing the function's interface: it now takes a numeric `discount_percent` instead of a code string, so I also had to update the call in `main()` and add range validation, while making sure the promo price was still 16.0. The mutable default argument was also tricky to *understand*: the code looked fine, but the `[]` default is created once and shared across every call, so order history leaked between customers.

2. Did the static analysis tools report any false positives? If so, give an example.

Bandit's B311 warning about `random` is borderline. `random` is fine for things like games or simulations, and Bandit flags it regardless of what it's used for. In this case it was generating a booking PIN, which is security-sensitive, so I still switched to `secrets`, but the tool can't tell the difference by itself.

More important was a false *negative*: none of the three tools flagged the hardcoded `BOX_OFFICE_SECRET_PASS_2026` being printed to the console. Bandit only detects hardcoded secrets in variables with names like `password`. I found it by reading the code and fixed it by reading the key from an environment variable. This showed me that static analysis supports manual review but doesn't replace it.

3. How would you integrate static analysis tools into your actual software development workflow?

Locally, I would run Flake8 and Pylint through a pre-commit hook (a script that runs automatically before every commit) so style and quality issues are caught before code is saved. In a team, I would add all three tools to a CI pipeline (e.g. GitHub Actions) that runs on every pull request and blocks merging if Bandit finds a medium/high severity issue or the Pylint score drops below a threshold like 9.5. I would also enable linting in my editor (VS Code) so problems show up while typing.

4. What tangible improvements did you observe in code quality, readability, or robustness after the fixes?

- Pylint score went from 5.37/10 to 10.00/10; Bandit issues from 5 (2 High, 1 Medium, 2 Low) to 0; Flake8 issues from 7 to 0.

Line: 1 Col: 1

reflection.md

reflection 〉 Reflection — Lab 5: Static Code Analysis

Locally, I would run Flake8 and Pylint through a pre-commit hook (a script that runs automatically before every commit) so style and quality issues are caught before code is saved. In a team, I would add all three tools to a CI pipeline (e.g. GitHub Actions) that runs on every pull request and blocks merging if Bandit finds a medium/high severity issue or the Pylint score drops below a threshold like 9.5. I would also enable linting in my editor (VS Code) so problems show up while typing.

4. What tangible improvements did you observe in code quality, readability, or robustness after the fixes?

- Pylint score went from 5.37/10 to 10.00/10; Bandit issues from 5 (2 High, 1 Medium, 2 Low) to 0; Flake8 issues from 7 to 0.
- Security: no more arbitrary code execution (`eval`), shell injection (`os.system`), weak hashing (MD5), or exposed secrets.
- Robustness: the file is always closed thanks to `with`, cancelling a non-existent seat now reports an error instead of failing silently, and the shared-list bug is gone.
- Readability: every function has a docstring, names follow snake_case, and `check_seat_status` and `get_theater_summary` are shorter and clearer.
- The program's output stayed the same, so the fixes didn't break anything.

Line: 1 Col: 1